

SPEC-1-Terms & Policies Reviewer

Status: v2 Enhanced – Performance optimizations, accuracy improvements, and UX enhancements added

Cadence: Weekly telemetry retention (180 days) **locked**

Background

Modern Terms of Service (ToS) and Privacy Policies are long, frequently updated, and written in ways that make it hard for non-lawyers to spot risk. Users want fast, reliable insight into where their rights may be limited (e.g., mandatory arbitration, class-action waivers, unilateral change clauses) and how their data is collected, shared, retained, and monetized. Privacy regulations (e.g., GDPR, CCPA/CPRA) add jurisdiction-specific obligations that are easy to miss, especially when policies are split across ToS, Privacy, Cookies, and supplemental notices.

Problem to solve: Provide an automated reviewer that ingests policy documents (URLs, PDFs, pasted text), extracts key clauses, flags potentially rights-infringing or high-risk language, maps findings to relevant jurisdictions/regulatory themes, and explains implications in plain language accompanied by citations to the exact passages.

Primary stakeholders: Individual consumers, SMB founders and product leads, privacy champions in startups, digital rights advocates, and procurement reviewers who must vet third-party services quickly.

Document scope: ToS, Privacy Policy, Cookie Policy, EULA, Data Processing Addendum (DPA), in-app notices, **data storage/retention & residency policies**, and **third-party/processor & sub-processor implications**. Version diffs between policy revisions are in scope to surface newly introduced risks.

Non-goals: This tool does not dispense legal advice or replace counsel; instead it accelerates triage and due diligence by highlighting issues and providing traceable evidence.

Key challenges: Highly variable formats and legal phrasing; cross-references across multiple docs; geo-specific rules; evolving definitions (e.g., "sale" of data); dynamic website content; and multilingual policies. **Performance at scale with large document sets; maintaining high accuracy while processing quickly; avoiding vendor domain blocking.**

Indicators of success: High precision/recall on risky-clause detection; reduced time-to-insight; user-rated clarity of explanations; accurate per-jurisdiction tagging of findings; **model**

performance stability over time; successful A/B test improvements.

Assumptions (v2):

- **Regions & language:** English-first; supported jurisdictions: US, EU, UK, **Canada**; machine-translate other languages to English for analysis.
- **Day-1 jobs-to-be-done:** (a) Upload/URL ingest → risk summary with citations; (b) Watchlist vendors → change alerts & diffs; (c) Side-by-side compare **2-3** vendors; **(d) Quick scan mode for rapid assessment.**
- **Rubric support:** Adopt the attached rubric as **v0.1** quality gate (target average ≥ 4.2 before pilot; categories & weights as specified).
- **Performance targets:** Parallel processing for sub-6-minute completion on documents up to 100 pages.

Requirements

Prioritization: MoSCoW

Must-have

- **Platform baseline (AWS):** Use AWS-native services for core ops and alerting (CloudWatch, EventBridge, SNS, **SES, AWS Chatbot**); encrypt data with KMS; VPC-private data stores.
- **Multi-source ingest:** URL, HTML, PDF, DOCX, RTF, TXT; crawl linked policy pages (ToS, Privacy, Cookies, EULA, DPA, in-app notices).
- **Clause detection & tagging:** Arbitration, class-action waiver, unilateral change, consent model, targeted advertising/behavioral profiling, "sale/share" definitions, children's data, sensitive data, cross-border transfers, **data storage/retention & residency, third-party processors/sub-processors**, data subject rights (access/erasure/opt-out), dark patterns, **industry-specific patterns (healthcare HIPAA, fintech regulations).**
- **Evidence binding:** Every finding shows exact excerpt + linkable citation; a **Verify** view highlights lines in context.
- **Jurisdiction mapping (v1):** US (CCPA/CPRA themes), EU (GDPR themes), UK (UK GDPR/DPA 2018), **Canada (PIPEDA + provincial notes)**; flag gaps/mismatches per region.
- **Risk summary:** Severity per category with rationale; plain-language implications and recommended next action; **confidence scoring for each finding.**
- **Compare vendors:** Side-by-side compare **2-3** vendors with category deltas and overall risk score.

- **Watchlist & diffs:** Track vendors; detect policy updates; show redlines and change summaries; **alerts via Email (Amazon SES) and Slack (AWS Chatbot).**
- **Rubric scoring:** Compute rubric **v0.1** scores (Product Integrity, Legal Signal Quality, Privacy & Security, Accessibility/Usability, Visual/IXD, Performance/Reliability, Governance Readiness) and output a scoring sheet.
- **Export & share:** PDF and CSV/JSON exports; shareable read-only link.
- **Privacy & security baseline:** In-product disclaimer (not legal advice); encryption at rest and in transit; data minimization; deletion controls; **prominent legal disclaimer positioning in UI.**
- **User experience modes:**
 - **Quick scan mode:** Highlights only critical issues for rapid assessment
 - **Progressive disclosure:** High-level summary first, then drill-down to details
 - **Guided walkthrough:** Step-by-step explanation of findings for non-technical users

Should-have

- **Granular jurisdictions:** US state-level and **Canadian provincial (e.g., Quebec Law 25)** enhancements with **documented trigger conditions for implementation.**
- **Additional alert channels:** **Microsoft Teams via AWS Chatbot** and **generic webhooks via EventBridge API Destinations.**
- **Browser extension:** One-click capture of current policy URL for ingest.
- **Admin & org:** Workspaces, roles (viewer/editor/admin), SSO (SAML/OIDC) for enterprise.
- **API:** Ingest and results retrieval for integration into vendor-risk workflows.
- **Accessibility:** WCAG 2.2 AA conformance checklist in CI/QA; keyboard-first UX.
- **Rate limiting:** Per-domain rate limiting with exponential backoff to avoid blocking.
- **A/B testing infrastructure:** Compare detection strategies and UI variations.

Could-have

- **Negotiation helpers:** Draftable email language and clause-swap suggestions (template-based, not legal advice).
- **Model tuning:** Few-shot and ruleset customization per organization; custom risk taxonomies; **feedback loop for continuous improvement.**
- **Cookie/SDK scanner:** Optional URL scan to reconcile declared vs observed trackers.

- **Source reliability scoring:** Weight regulatory updates based on source authority.

Won't-have (MVP)

- Automated legal redlining or contract generation; native mobile apps; real-time counsel.

Method

Cloud Platform Decision

- Cloud: AWS (locked).
- **Home Region (MVP): US East (N. Virginia, `us-east-1`).**
- **Rationale:** Native support for Bedrock Agents/Knowledge Bases, Textract, OpenSearch Serverless (vector), and turnkey alerting (Chatbot/SES). EU/UK/CA data transfer handled contractually (see Data Residency Posture).

System Architecture (MVP + v2 Enhancements)

A pragmatic, AWS-native pipeline optimized for explainability, verifiability, and performance at scale.

- **Ingress & Capture:** User pastes a URL or uploads a file (HTML/PDF/DOCX/RTF/TXT). A lightweight **Ingest API** (REST) creates a job and drops a manifest into **S3**.
- **Crawler & Fetcher:** Resolves the main URL and crawls linked policy pages (ToS/Privacy/Cookies/EULA/DPA) with per-domain rate limits **and exponential backoff**; snapshots HTML and binaries into S3 with content hashes.
- **Text Extraction:**
 - HTML: Readability/trafilatura-style cleaner → HTML→text.
 - PDFs/images/scans: OCR via managed service; preserve page breaks/locations; **cache results for repeated processing**.
 - DOCX/RTF/TXT: Direct parsers.
- **Normalizer & Chunker:** Normalize whitespace, headings, lists; produce overlapping chunks (e.g., 1,200-1,600 tokens, 15-20% overlap) and page/section anchors; **parallel chunk processing for large documents**.
- **Detection & Tagging (hybrid):**
 - **Rules pass:** high-precision patterns/lexicons for signature clauses (arbitration, class-action waiver, unilateral change, retention/storage/residency, third-party processors/sub-processors, etc.); **industry-specific pattern sets**.

- **ML pass:** per-chunk clause classification, jurisdiction cues, and severity hints; ensemble with rules for calibrated scores; **confidence thresholds with human review flags for low-confidence findings.**
- **Pre-computed embeddings:** Common clause patterns pre-embedded for faster matching.
- **Evidence Binding & Explainability:** For each finding, store exact excerpt, page/section, offsets, surrounding context, **and confidence score.**
- **Similarity Index:** Semantic search for clauses using a managed vector/keyword index to power quick evidence lookup and cross-vendor comparisons; **monitor costs and implement query optimization.**
- **Versioning & Diffs:** Every crawl creates a new immutable snapshot; compute token-level diffs and label risk-relevant additions/deletions.
- **Scoring:** Compute per-category risk and a rubric-weighted quality score; persist a scoring sheet per run; **include confidence intervals.**
- **Alerts:** On significant changes or watchlist updates, emit events to chat/email channels.
- **Feedback Loop:** User corrections improve ML models through active learning pipeline.

Agentic Layer (MVP + Next)

We add an agentic control layer for tasks that benefit from tool-use, retrieval, and iterative reasoning while keeping Step Functions as the reliable orchestrator of record.

- **Policy Reviewer Agent (MVP):** Consolidates findings with tool calls; **applies contextual intelligence based on industry.**
- **Regulatory Monitor Agent (MVP+):** Periodically scans official sources for **AI laws/regulations** and **youth/minors privacy** guidance across US/EU/UK/CA; drafts weekly/bi-weekly briefs with citations; flags items that impact our detection rules or disclosures; **scores source reliability.**
- **DevOps Copilot Agent (MVP+):** ChatOps in Slack for **read-only diagnostics** and **proposing** remediations via SSM Change Manager (approval-gated); can trigger Incident Manager runbooks under strict templates.
- **Orchestrator (Parent) Agent (Next):** Routes tasks among agents; enforces cost/time budgets; writes audit trails.

Algorithms & Pipeline Details

1) Ingest & Crawl

- Accept URL/file → enqueue job; for a URL, crawl same-site policy links with depth=1-2 (robots-aware) and MIME allowlist.
- Hash and dedupe by canonical text to avoid noisy churn from cosmetic edits.
- **Implement rate limiting with exponential backoff to avoid domain blocking.**

2) Extraction & Normalization

- Prefer text-native paths: HTML→text; DOCX/RTF→text; for scanned PDFs/images, OCR.
- Preserve page numbers and header hierarchy; segment into overlapping chunks with anchors (`section_id`, `page`).
- **Cache Texttract results for repeated PDF processing.**

3) Clause Detection (Hybrid)

- **Rules pass** (deterministic): curated regex/phrase lists per category and jurisdiction cues; **industry-specific pattern libraries.**
- **ML pass** (probabilistic): per-chunk multi-label classification for ~20-30 clause types + severity hints; add a jurisdiction tagger. Ensemble with rules via calibrated logistic stacking to output `score ∈ [0,1]` and integer `severity 0-4`.
- **Confidence scoring:** Each finding includes confidence level (0-100%); findings below 60% confidence flagged for optional human review.
- **Contextual patterns:** Industry-specific detection (e.g., HIPAA for healthcare, PCI DSS for payments).

4) Evidence Binding & Explainability

- For each finding, store: excerpt, start/end offsets, page, 2-3 sentence context window, **confidence score, and industry relevance.**
- UI "Verify" view highlights the exact lines in the original snapshot.

5) Performance Optimization

- **Parallel processing:** Process chunks concurrently after extraction phase.
- **Pre-computed embeddings:** Maintain library of common clause embeddings.

- **Caching strategy:** Cache extraction results, embeddings, and frequent queries.
- **Query optimization:** Batch vector operations; implement query result caching.

6) Monitoring & Model Health

- **Drift detection:** Monitor model performance metrics for degradation.
- **A/B testing:** Infrastructure for comparing detection strategies.
- **Feedback integration:** Active learning from user corrections.

Security & Privacy Guardrails (Enhanced)

- Principle of least privilege IAM; server-side encryption (KMS) for S3/Aurora; signed URLs for snapshot viewing.
- Data minimization: retain only text needed for findings; redact PII in logs; configurable retention (e.g., 90/180/365 days).
- **Enhanced legal disclaimers:**
 - Prominent positioning in UI header/footer
 - Modal on first use requiring acknowledgment
 - Inline reminders for high-stakes findings
 - Clear documentation of Quebec Law 25 trigger conditions
- Model card describing limitations and failure modes.

Implementation

Performance Targets & SLOs (Updated)

- **p95 end-to-end job $\leq$ 6 min** for documents up to 100 pages
 - Achieved through parallel chunk processing
 - Pre-computed embeddings for common patterns
 - Caching layer for repeated operations
- **Alert delivery $\leq$ 60 s** after diff detection
- **Quick scan mode $\leq$ 2 min** for critical issues only
- **API response time $\leq$ 500ms** for cached results

Cost Optimization Strategy

- **OpenSearch Serverless:**

- Start with minimum OCUs
- Implement query result caching
- Monitor vector operation costs
- Consider hybrid search (keyword + vector) to reduce costs
- **Texttract**: Batch processing during off-peak hours
- **S3**: Intelligent tiering for snapshots

Gathering Results

MVP Scorecard (Enhanced Targets)

- **Detection quality** (labeled test set of 200 docs across ToS/Privacy/DPA/EULA)
 - High-risk categories: **precision ≥ 0.80 , recall ≥ 0.70**
 - Medium-risk categories: precision ≥ 0.75 , recall ≥ 0.65
 - **Confidence calibration**: 90% of high-confidence ($>80\%$) findings should be accurate
- **Model stability**: Performance drift $\leq 5\%$ over 90 days
- **Industry-specific accuracy**: 85% agreement with domain experts
- **User experience metrics**:
 - Quick scan satisfaction $\geq 4.3/5$
 - Progressive disclosure engagement $\geq 70\%$
 - Time to first insight ≤ 30 seconds

Measurement Plan (Enhanced)

- **Ground truth**: Label a fixed corpus (200 docs; refresh quarterly). Store labels in `gold_labels` with per-category severity **and confidence scores**.
- **Drift monitoring**: Daily model performance checks with automated alerts for $>3\%$ degradation.
- **A/B testing**: Compare detection strategies on 10% of traffic; track precision/recall/user satisfaction.
- **Industry validation**: Quarterly review with domain experts for industry-specific patterns.

Continuous Improvement Loop

- **Weekly**: Review false positives/negatives; update rules and confidence thresholds

- **Bi-weekly:** Analyze user feedback; retrain models with corrected labels
- **Monthly:** Industry pattern review; update contextual detection rules
- **Quarterly:** Full model retraining; corpus refresh; rubric weight adjustment

Implementation Checklist (Enhanced Sprint-ready)

Sprint 0 - Platform & Guardrails

- Provision core AWS with performance optimization in mind
- Implement caching layer (ElastiCache)
- Set up A/B testing infrastructure
- Configure drift detection alerts

Sprint 1 - Ingest & Evidence

- Build parallel processing pipeline
- Implement rate limiting with backoff
- Add caching for extraction results
- Create quick scan mode endpoints

Sprint 2 - Detect & Search

- Deploy industry-specific pattern sets
- Implement confidence scoring system
- Pre-compute common embeddings
- Add progressive disclosure UI

Sprint 3 - Classify, Compare, Alerts

- Deploy feedback collection system
- Implement active learning pipeline
- Add source reliability scoring
- Create human review queue for low-confidence findings

Sprint 4 - Optimization & Monitoring

- Performance testing with parallel processing
- Cost optimization for vector operations

- Drift detection implementation
- A/B test framework deployment

Need Professional Help in Developing Your Architecture?

Please contact me at sammuti.com :)